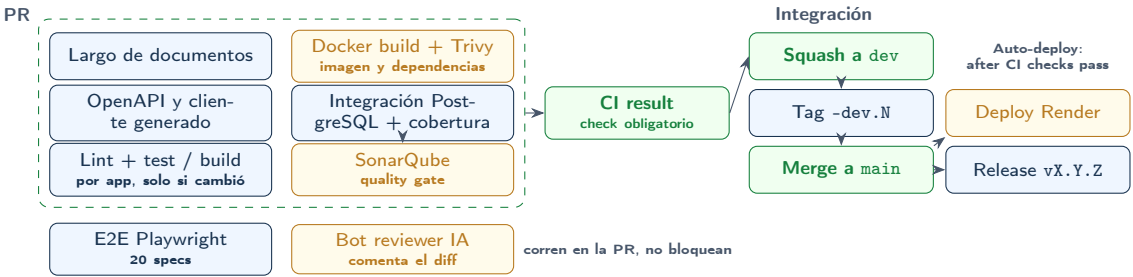
Pipeline de CI/CD



137 / 181
CI exitosas desde 11/10

67 / 67
releases y tags

8 / 9
E2E exitosas

16 / 18
revisiones del bot

Las 36 ejecuciones fallidas de CI son casi todas de PR (35): el gate cumplió su función. E2E corre en PR, pero aún no es check obligatorio.

Seguridad y calidad: SCA, SAST y revisión con IA

SCA: Trivy

En CI: `fs` e imagen Docker; falla con HIGH o CRITICAL con corrección.

Auditoría 01/11, repo completo:

- 0 CRITICAL, 0 HIGH.
- 3 MEDIUM en el backend: `glob`, `minimatch` y `qs`, todas con versión corregida.

SAST: SonarQube

En CI: quality gate que bloquea la PR.

Auditoría 01/11, 9 465 líneas:

- Quality gate **OK**; cobertura 94,1 %; duplicación 0,0 %.
- 11 issues: 1 bug crítico (`sort` sin comparador en el libro de notas) y 10 code smells, 8 de ellos `tabIndex`.

Code review con IA

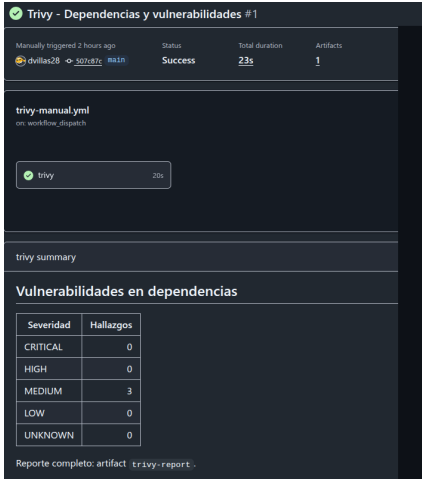
Bot propio: GitHub Actions + Gemini; lee el diff de cada PR a `dev` o `main` y comenta.

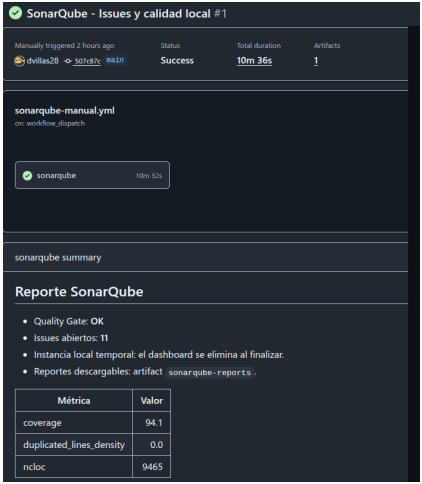
Criterios del dominio: aislamiento, roles, notas y tests (ADR `define-bot-pr-reviewer`).

- No bloquea: evita el riesgo R-16 de frenar el flujo.
- Pendiente: ajustar falsos positivos (#173).

El bug crítico y la actualización de dependencias se resuelven esta semana

Evidencia: auditorías del 01/11 sobre `main`





Trivy (SCA)
0 críticas y 0 altas. Las 3 medias tienen versión corregida.

SonarQube (SAST)
Quality gate OK, cobertura 94,1 % y 0 % de duplicación en 9 465 líneas.

Cómo se usan
Se lanzan a pedido desde Actions y dejan el reporte como artifact. Los gates de cada PR siguen activos en CI.